CASE STUDY

The CareCloud Medical-Records Breach of March 2026: A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people in this breach are patients. CareCloud runs electronic health record (EHR) and clinical documentation services for healthcare organizations [8] (**Confirmed**), so most affected people had no direct relationship with it [10] (**Reported**); their doctors and clinics chose the vendor (**Inferred**). HHS lists CareCloud, Inc. as a business associate and records 3,756,469 individuals affected, submitted on 24 July 2026 as a Hacking/IT Incident on a Network Server [9] (**Confirmed**).

The intrusion ran from 10 to 16 March 2026 inside "one of CareCloud's AWS environments" [8] (**Confirmed**). Forensics later found that an unauthorized third party had accessed one cloud account supporting an EHR environment and exfiltrated patient-related information, including PII and PHI, for a substantial number of individuals [3] [4] (**Confirmed**). The company first disclosed it as an eight-hour "temporary network disruption" contained the same day, caused by an unauthorized third party, with any access to or exfiltration of patient data still under assessment [1] (**Confirmed**). No filing or letter names an actor, a malware family, a CVE or an entry method [1] to [4] [8] (**Confirmed** as an absence in the opened record).

Key facts at a glance

Field	Value
Victim organization	CareCloud, Inc. (Somerset, New Jersey; Nasdaq CCLD), CareCloud Health division, 1 of its 6 EHR environments [1] (**Confirmed**)
People affected	Patients of healthcare organizations that use CareCloud's EHR services [8] (**Inferred** that they are those organizations' patients); 3,756,469 per HHS [9] (**Confirmed**); SEC filings say only "a substantial number of individuals" [3] [4] (**Confirmed**)
Access window	10 to 16 March 2026 [6] [8] (**Confirmed**); about six days of dwell (**Inferred**)
Entry point	One cloud account supporting the EHR environment; how it was obtained is not stated [3] [4] (**Confirmed**)
Data	Full name plus one or more other elements per individual; PII and PHI [3] [8] (**Confirmed**)
Operational impact	Partial loss of functionality and data access in one EHR environment for about 8 hours on 16 March, restored that evening [1] (**Confirmed**)
Attribution	"An unauthorized third party"; no actor named [1] to [4] (**Confirmed**); no group claim as of 19 August [10] (**Reported**)
CVE and KEV	None in the record [1] to [4] [11] (**Confirmed** as an absence in the opened record; that no CVE applies is **Inferred**)
SEC disclosure	Form 8-K Item 1.05 filed 27 March 2026; materiality decided 24 March [1] (**Confirmed**)
Regulator status	No regulator has asserted a claim as of 5 November [4] (**Confirmed**)

Key findings

- **The first disclosure was the least complete.** The 8-K described a same-day "temporary network disruption" by an unauthorized third party and left exfiltration open [1]; the 10-Qs and the consumer notice later showed six days of prior access and confirmed exfiltration [2] [3] [8] (**Confirmed** facts; that the 8-K framing understated the event is **Inferred**).
- **One cloud account was enough.** The Q2 and Q3 10-Qs put the intrusion on a single cloud account supporting one EHR environment [3] [4] (**Confirmed**). The record points to a cloud identity, not to any named software flaw; how the account was obtained is not stated (**Inferred**).
- **Separation appears to have held the blast radius.** The company says only one of six EHR environments was touched and no other division was affected [1] (**Confirmed** as the company's statement; the control effect is **Inferred**).
- **The count lives at HHS, not the SEC.** 3,756,469 appears on the HHS portal [9]; no SEC filing states a number [3] [4] (**Confirmed**).

Top recommendations

1. Treat every cloud account that can reach a patient database as a crown-jewel identity: phishing-resistant MFA, short-lived credentials and no standing keys [3] (**Inferred** from the entry point).

2. Alert on bulk database reads and large outbound transfers from EHR cloud accounts, so detection does not wait for a service disruption [1] [8] (**Inferred**).
3. Keep EHR tenants in separate cloud accounts with separate identities, as the six-environment split appears to have done here [1] (**Inferred**).
4. In vendor contracts, require the business associate to state dwell time, data elements and counts to each provider customer on a fixed schedule [3] [8] (**Inferred**).

Scope and method

This brief covers the March 2026 CareCloud intrusion and its disclosure, notification, litigation and regulatory record through the Q3 10-Q of 5 November 2026. The sector picture is in the Healthcare Threat Watchlist [14]. Every source was opened directly by URL on 11 November 2026; no search-engine queries were run, so press naming of any group was not checked. Court dockets, the Maine AG list and any leak site were not opened.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: SEC filings, the HHS and California AG records, CareCloud's consumer notice, or library data. A company's account of its own investigation is Confirmed as that company's statement
Reported	Journalism or a secondary account of a primary not opened here
Demonstrated	Something this study ran: the search of Intelligence Hub exports for a CareCloud row
Inferred	This study's own reasoning from cited facts, labelled where it appears

Part 1: what happened

Date (2026)	Event	Sources	Grade
10 March	Unauthorized access to one of CareCloud's AWS environments begins; California lists this as the breach date	[6] [8]	Confirmed
16 March	Network disruption in CareCloud Health: 1 of 6 EHR environments partially loses functionality and data access for about 8 hours; restored that evening; contained the same day	[1]	Confirmed
16 March	Last date of unauthorized activity; no evidence of any after it	[3] [4] [8]	Confirmed
After 16 March	CareCloud notifies its cyber insurer, engages a Big Four firm's cyber response team for containment and forensics, and reports to law enforcement (agency not named)	[1]	Confirmed
24 March	CareCloud decides the incident is material because of the sensitivity of the potentially affected information; operations not materially affected	[1]	Confirmed
27 March	Form 8-K, Item 1.05 filed (Date of Report 24 March); patient data access or exfiltration still being assessed	[1] [5]	Confirmed
7 May	Q1 10-Q: forensics find a yet-to-be-determined amount of data exfiltrated; initial access about one week before 16 March; two patient class actions served	[2]	Confirmed
June	Class actions consolidated in the U.S. District Court for the Southern District of Florida; consolidated amended complaint filed	[3] [4]	Confirmed
24 June	CareCloud determines the affected data elements	[8]	Confirmed
24 July	HHS breach report submitted: 3,756,469 individuals	[9]	Confirmed
25 July	California AG listing reported; individual notices begin	[6] [7] [10]	Confirmed (AG), Reported (notice start)
6 August	Q2 10-Q: one cloud account accessed; PII and PHI exfiltrated for a substantial number of individuals; $100,000 insurance retention	[3]	Confirmed
19 August	BleepingComputer reports the HHS count and that no ransomware or extortion group had claimed the attack	[10]	Reported
5 November	Q3 10-Q: no regulator claim; a San Diego Superior Court action removed to the Southern District of California; settlement discussions ongoing; retention accrued	[4]	Confirmed
5 November	EDGAR shows no 8-K/A amending Item 1.05 through this date; the only 2026 8-K/A (24 July) covers Item 1.01	[5]	Confirmed
17 December	Enrollment deadline for the offered identity monitoring	[8]	Confirmed

Part 2: the intrusion record

Four documents carry the technical record, and they describe the same event at different depths.

The 8-K (27 March) describes the 8-hour disruption, says the environment stores patient information, and says the company was still assessing whether patient data was accessed or exfiltrated [1] (**Confirmed**).

The Q1 10-Q (7 May) adds that initial unauthorized access began about one week before 16 March and that a yet-to-be-determined amount of data had been exfiltrated [2] (**Confirmed**).

The consumer notice fixes the window at 10 to 16 March in "one of CareCloud's AWS environments" and says the third party "claimed to have exfiltrated data from databases" there [8] (**Confirmed**). The sample letter lists full name plus one or more other elements, leaving the rest as a placeholder; the California copy's file name references SSN, so Social Security numbers were likely in scope for at least that letter variant [8] (**Confirmed** for the file name; SSN involvement is **Inferred**).

The Q2 and Q3 10-Qs state the forensic finding: an unauthorized third party accessed one cloud account supporting the affected EHR environment and exfiltrated patient-related information, including PII and PHI, for a substantial number of individuals [3] [4] (**Confirmed**). The Q2 risk factor still uses the softer "claimed to have exfiltrated" wording beside the notes' "determined" [3] (**Confirmed**).

What none of them says matters as much. No filing or letter names how the cloud account was obtained, what credential type was used, how the third party caused the 8-hour disruption, how the data left, or what alerted defenders [1] to [4] [8] (**Confirmed** as an absence in the opened record). No CVE, vulnerability, malware family or tool appears [1] to [4] [8] (**Confirmed** as an absence in the opened record; that no CVE applies is **Inferred**), and the Intelligence Hub feed and its March, April and August 2026 exports carry no CareCloud row [11] [12] (**Confirmed** for the feed, **Demonstrated** for the exports). This study therefore binds no exploit technique and no exfiltration channel (**Inferred**).

Part 3: who and why

Attribution in the primary record goes no further than "an unauthorized third party" (the 8-K also says "the threat actor") [1] to [4] (**Confirmed**).

- **No named actor.** None of the SEC filings or the consumer notice names a group, person or nation [1] to [4] [8] (**Confirmed**). As of 19 August no ransomware or extortion group had claimed the attack [10] (**Reported**). Press naming after that date was not checked.
- **No stated motive.** The third party "claimed" to have exfiltrated data [3] [8]. That wording fits an extortion contact, but no ransom demand, payment or leak publication appears in the filings or notice [3] [4] [8] (**Confirmed** as an absence in the opened record; the extortion reading is **Inferred**).
- **Law enforcement.** CareCloud reported the matter to law enforcement without naming the agency [1] (**Confirmed**).

Part 4: impact and response

The patients. HHS records 3,756,469 individuals [9] (**Confirmed**), the figure BleepingComputer reported from the same portal [10] (**Reported**). Victims are patients of the healthcare organizations that use CareCloud's EHR and clinical documentation services [8] (**Confirmed** that CareCloud serves those organizations; that the victims are their patients is **Inferred**). BleepingComputer notes that CareCloud has no direct relationship with patients [10] (**Reported**). Individuals were offered 12 or 24 months of IDX credit and CyberScan monitoring, a $1,000,000 insurance reimbursement policy and identity theft recovery services, with enrollment closing on 17 December 2026 [8] (**Confirmed**). The notice says the company is not aware of identity fraud from the incident [8] (**Confirmed** as its statement).

The company. Insurance is expected to cover forensics, remediation, notification, litigation and legal costs apart from a $100,000 retention, which was accrued [3] [4] (**Confirmed**). The Q3 risk factors tie future risk to AI-enabled attacks and to CareCloud's own AI products, CirrusAI and StratusAI, which process PHI on third-party cloud [4] (**Confirmed** as risk language, not an incident finding).

Regulators. The 8-K promised an amendment for undetermined Item 1.05(a) information [1], but no Item 1.05 8-K/A was filed through 5 November [5]; the updates came in the 10-Qs instead [2] [3] [4] (**Confirmed**). HHS lists the breach [9]; California lists a breach date of 10 March and a report date of 25 July [6] [7] (**Confirmed**). As of 5 November no regulatory agency has asserted a claim; the risk factors name HHS OCR and state attorneys general as possible investigators [4] (**Confirmed**).

Courts. Two class actions were served by Q1 [2]; actions were consolidated in the Southern District of Florida in June [3]; a San Diego Superior Court action was removed to the Southern District of California, and settlement discussions are ongoing [4] (**Confirmed** as the company's account; dockets not opened).

KEV and CVE. The Intelligence Hub feed, which carries KEV catalog 2026.11.10, has no CareCloud row and the opened filings cite no CVE [11] (**Confirmed** for the feed); government advisories were not checked because no CISA site search was run.

Part 5: the defender and vulnerability-management view

- **A CVE queue would have shown nothing.** The record shows a cloud identity, a database and six days of quiet; it names no missing patch, though it does not say how the account was obtained [3] [8] (**Inferred**). Exposure management for EHR hosting has to score identities and data stores, not only software.
- **Watch the control plane.** Access ran six days before the 16 March disruption, the day the company says it discovered the incident [1] [8] (**Confirmed** for the dates; what alerted defenders is not stated). Alerts on new access keys, unusual source locations and database export calls are the signal the record lacks (**Inferred**).
- **Read the 10-Q, not just the 8-K.** Here the 8-K was the first and least complete notice [1] [2] [3] (**Inferred**); provider customers should track the vendor's periodic filings and HHS entry.
- **Segment by tenant.** Six separate EHR environments let the company say five were untouched [1] (**Inferred** control effect).

What is overstated and what is understated

- *Overstated:* calling this a ransomware attack. No filing or notice mentions ransomware or encryption, and the disruption lasted about 8 hours [1] [8] [10] (**Inferred**). Treating 3,756,469 as an SEC-disclosed number is also wrong: the SEC filings never state a count [3] [4] (**Confirmed**).
- *Understated:* the 8-K's "temporary network disruption" framing, written before the forensic findings, though it named an unauthorized third party and left exfiltration open, understates a six-day intrusion with confirmed exfiltration that HHS records at 3,756,469 individuals [1] [3] [9] (**Inferred** from **Confirmed** facts). The missing Item 1.05 amendment means the SEC incident filing still carries the early framing [5] (**Confirmed**).

MITRE mappings

This Part binds the verified record to ATT&CK v20.0 Enterprise, CAPEC and D3FEND, with names and tactics from the library's `data/attack/` and `data/weaknesses/` files [13]. No source describes industrial systems, so no ATT&CK for ICS techniques apply.

Groups, software and campaigns

No group, software or campaign object is bound: the record names no actor, malware or tool [1] to [4] [8] (**Confirmed** as an absence in the opened record).

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1078.004	Valid Accounts: Cloud Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	An unauthorized third party accessed one cloud account supporting the EHR environment, 10 to 16 March 2026 (Q2 10-Q, 6 August)	[3] [4] [8]
T1213.006	Data from Information Repositories: Databases	Collection	The third party claimed to have exfiltrated data from databases in the environment (consumer notice); exfiltration of PII and PHI determined by forensics (Q2 10-Q)	[3] [8]

Fit notes (**Inferred**): T1078.004 fits the Q2 and Q3 wording directly. T1213.006 is a partial fit: "databases" comes from the actor's claim as the notice relays it, and the forensic finding says only "patient-related information". T1530 Data from Cloud Storage is left out because the record says databases, not object storage. No exfiltration technique is bound because the channel is not stated. No impact technique is bound: the mechanism of the 8-hour disruption is not stated, and no ransom or extortion appears in the record, so T1486, T1499 and T1657 are left out.

CWE and CAPEC

No CVE applies, so this study binds no CWE [1] to [4]. CAPEC entries the library relates to the parents of this study's techniques [13]:

CAPEC	Name	Via	Where it meets the record
CAPEC-560	Use of Known Domain Credentials	T1078	Use of one cloud account's access [3] (**Inferred**, partial fit: the credential type is not stated)

CAPEC	Name	Via	Where it meets the record
CAPEC-150	Collect Data from Common Resource Locations	T1213	Collection from databases in the EHR environment [8] (**Inferred**, partial fit)

D3FEND countermeasures

D3FEND countermeasure	Technique the library maps it to	Where it meets the record
User Account Permissions (D3-UAP)	T1078.004	One cloud account reached patient data in an EHR environment [3]
Access Modeling (D3-AM)	T1078.004	Knowing which cloud identities can read which EHR databases [3] (**Inferred**)
Agent Authentication (D3-AA)	T1078.004	Stronger authentication for the account class that was used [3] (**Inferred**)
Account Locking (D3-AL)	T1078.004	Same-day containment on 16 March; method not stated [1] (**Inferred**)
Restore User Account Access (D3-RUAA)	T1078.004	Restoration of functionality and data access that evening [1] (**Inferred**)

The library maps no D3FEND countermeasure to T1213.006. Multi-factor Authentication (D3-MFA) is what the entry point points to, though the library does not map it to T1078.004. Related ATT&CK mitigations the library maps to these techniques: M1032 Multi-factor Authentication, M1026 Privileged Account Management, M1018 User Account Management, M1036 Account Use Policies, M1047 Audit and M1041 Encrypt Sensitive Information. See the D3FEND Reference.

Navigator layer

The study's Navigator layer is `navigator/library-layers/carecloud-breach-2026.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20 Enterprise; scores measure the tie to this record (100 direct fit to a primary, 60 primary with partial fit), and each comment names its source numbers.

Cross-cutting themes

- **Vendor breaches carry the counts.** The Healthcare Threat Watchlist already names CareCloud, with Aesto and TriZetto, among the business associates and vendors behind 2026's largest HHS entries [14] (**Confirmed** as library text). Change Healthcare 2024, at 192,700,000 individuals on HHS, is the business-associate precedent [15] (**Inferred** lineage).
- **Theft without encryption.** As in the Cl0p file-transfer breaches, the harm is the data taken, not systems locked [3] (**Inferred**).
- **Disclosure moves in stages.** The 8-K, three 10-Qs, an HHS entry and a state notice each told part of the story; only together do they give the window, the entry point and the count [1] to [9] (**Inferred**).

Sources

All sources were opened on 11 November 2026. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings); copy them into a browser to open them. The EDGAR submissions index [5] lists each of them by accession number.

#	Source	URL	Opened	Grade
1	CareCloud, Inc., Form 8-K, Item 1.05, filed 27 Mar 2026 (Date of Report 24 Mar 2026)	`https://www.sec.gov/Archives/edgar/data/1582982/000149315226013239/form8-k.htm`	2026-11-11	Confirmed
2	CareCloud, Inc., Form 10-Q for Q1 2026, filed 7 May 2026	`https://www.sec.gov/Archives/edgar/data/1582982/000149315226021730/form10-q.htm`	2026-11-11	Confirmed
3	CareCloud, Inc., Form 10-Q for Q2 2026, filed 6 Aug 2026	`https://www.sec.gov/Archives/edgar/data/1582982/000149315226036363/form10-q.htm`	2026-11-11	Confirmed
4	CareCloud, Inc., Form 10-Q for Q3 2026, filed 5 Nov 2026	`https://www.sec.gov/Archives/edgar/data/1582982/000149315226050254/form10-q.htm`	2026-11-11	Confirmed
5	SEC EDGAR submissions index, CareCloud, Inc. (CIK 1582982)	data.sec.gov/submissions/CIK0001582982.json	2026-11-11	Confirmed
6	California Attorney General, data breach record sb24-627090, CareCloud, Inc.	oag.ca.gov/ecrime/databreach/reports/sb24-627090	2026-11-11	Confirmed
7	California Attorney General, data breach list search for CareCloud	oag.ca.gov/privacy/databreach/list?...carecloud	2026-11-11	Confirmed
8	CareCloud, sample consumer notification letter filed with the California Attorney General	oag.ca.gov/system/files/CareCloud_-_SSN_39739837v1.pdf	2026-11-11	Confirmed
9	HHS Office for Civil Rights, breach portal, HIPAA breach report (export)	ocrportal.hhs.gov/ocr/breach/breach_report_hip.jsf	2026-11-11	Confirmed
10	BleepingComputer, Healthtech firm CareCloud data breach impacts 3.7 million patients, 19 Aug 2026	bleepingcomputer.com/news/security/healthtech-firm-carecloud-...	2026-11-11	Reported
11	Team Star Wolf Intelligence Hub, feed.json (6,101 rows; KEV catalog 2026.11.10; no CareCloud row)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed
12	Team Star Wolf Intelligence Hub, v7 monthly article exports for 2026-03, 2026-04 and 2026-08 (searched; no CareCloud row)	teamstarwolf.github.io/intelligence-hub/data/v7/exports/articles-2026-08.csv	2026-11-11	Demonstrated
13	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `mitigation_to_technique.jsonl`, `technique_to_d3fend.jsonl`, `d3fend_countermeasures.jsonl`, `data/weaknesses/capec.jsonl` and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-11	Confirmed
14	TeamStarWolf library, Healthcare Threat Watchlist	/case-studies/HEALTHCARE_THREAT_WATCHLIST.md	2026-11-11	Confirmed
15	TeamStarWolf library, Change Healthcare 2024	/case-studies/CHANGE_HEALTHCARE_2024.md	2026-11-11	Confirmed

Not opened, so not cited as sources: the court dockets in the Southern Districts of Florida and California, the Maine Attorney General list (the URL tried returned 404), CISA's site, any news coverage after 19 August and any leak site.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Healthcare Threat Watchlist, Change Healthcare 2024, The Cl0p File-Transfer Breaches
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Healthcare Security Reference, Cloud Security Reference, Cloud Attack Reference, Identity Security Reference, Data Security Reference, Incident Response Reference, Regulatory Landscape Reference
- Vulnerability Prioritization Reference, Vulnerability Management Reference
- Techniques: T1078.004 Valid Accounts: Cloud Accounts, T1213.006 Data from Information Repositories: Databases
- Mitigations: M1032, M1026, M1018, M1036, M1047, M1041
- CAPEC: CAPEC-560, CAPEC-150
- Navigator layers, including this study's layer, carecloud-breach-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies